

CompTIA CY0-001

AI Security+ — Practice Questions & Verified Answers

48 questions • scraped from free-braindumps.com (pages 2–7)

Generated 2026-06-07 • Every answer cross-verified from two independent sources in the page (the marked option and the stated Answer key).

Question 1 (source: page 2)

Which of the following job roles in an organizational governance structure develops a model from business use cases?

- A. Platform architect
- B. AI risk analyst
- C. Machine learning operations (MLOps) engineer
- D. Data scientist [Correct]**

Correct Answer: D

Explanation

A data scientist develops models from business use cases by translating organizational needs into machine learning solutions. They prepare data, select algorithms, and build models that align with the use cases.

Question 2 (source: page 2)

An administrator, who works for a financial institution, is required to implement data security controls for data at rest within AI systems that involve data disclosure. Which of the following is the most suitable control?

- A. Data lineage
- B. Rate limits
- C. Encryption [Correct]**
- D. Masking

Correct Answer: C

Explanation

For financial institutions handling AI systems, protecting data at rest against disclosure requires encryption. Encryption ensures that even if the storage medium is accessed or compromised, the data remains unreadable without the proper decryption keys.

Question 3 (source: page 2)

A security engineer needs to monitor an AI-based system for runtime operations. The engineer is mostly concerned about the visibility of internal activity. Which of the following is the most appropriate monitoring solution?

- A. Deploying a security information and event management (SIEM) tool
- B. Implementing a web application firewall (WAF) with header logging
- C. Relying on vendor model controls and monitoring prompt inputs
- D. Enabling stack call and debugging level traces at the function level [Correct]**

Correct Answer: D

Explanation

For runtime visibility into internal activity of an AI system, the most suitable control is enabling stack calls and debugging-level traces. This provides granular insights into function-level execution, dependencies, and operations, which directly supports monitoring of runtime behavior.

Question 4 (source: page 2)

Which of the following should an auditor reference when reviewing a company's human resources AI systems for legal non-compliance?

- A. Organization for Economic Cooperation and Development (OECD) standard
- B. National Institute of Standards and Technology (NIST) AI Risk Management Framework 9RMF)
- C. European Union (EU) AI Act [Correct]**
- D. International Organization for Standardization (ISO)

Correct Answer: C

Explanation

The EU AI Act is legally binding legislation that specifically governs the use of AI systems, including those used in human resources for hiring, promotion, and evaluation. An auditor reviewing AI systems for legal non-compliance must reference this act because it establishes enforceable requirements related to transparency, bias, risk classification, and prohibited practices.

Question 5 (source: page 2)

An airline corporation wants to implement a chatbot application using a large language model (LLM) so its customers:

- Can ask question and receive answers about flight details.
- Have the option to upload files.

Which of the following security controls should the airline use to protect against malicious input and unauthorized use beyond the service-level agreement? (Choose two.)

- A. Prompt guardrails [Correct]**
- B. Role-based access controls
- C. Firewall rules
- D. Model token quotas [Correct]**

Correct Answer: A, D

Explanation

Prompt guardrails are needed to prevent malicious or manipulated inputs (prompt injection) from causing the chatbot to provide harmful, misleading, or unauthorized responses.

Model token quotas limit the amount of input/output a user can generate, preventing abuse or excessive usage beyond the service-level agreement (SLA).

Question 6 (source: page 2)

A security operations center (SOC) has a very high volume of logs and alerts. The manager proposes the implementation of machine learning (ML) system to help with triage. Which of the following tasks is most suitable?

- A. Applying filters on specific alerts
- B. Automatically patching vulnerable systems
- C. Identifying and classifying alerts [Correct]**
- D. Summarizing the content of alerts

Correct Answer: C

Explanation

Machine learning is best suited for analyzing large volumes of security data and distinguishing between true threats and false positives. By identifying and classifying alerts, the ML system helps the SOC prioritize incidents and reduce analyst workload.

Question 7 (source: page 2)

An organization recently created a custom model that integrates with a language model (LLM). The developer notices that the application programming interface (API) costs have increased. Which of the following is the best control to reduce cost?

- A. Implementing prompt templates
- B. Increasing central processing unit (CPU) and memory
- C. Reducing the model size
- D. Adjusting token limits [Correct]**

Correct Answer: D

Explanation

API costs for large language model integrations are directly tied to token usage (input + output tokens). By adjusting token limits, the organization can reduce unnecessary processing of overly long prompts or responses, thereby lowering overall API costs without changing model size or infrastructure resources.

Question 8 (source: page 2)

A security administrator needs to improve an AI model. During an initial investigation, the administrator notices that two successive login features are recorded every day, and then a successful login occurs after a specific time interval. All the successful login attempts have been during office hours. Which of the following techniques should the administrator use to improve the AI model's security?

- A. Access management
- B. Pattern recognition [Correct]**
- C. Signature matching
- D. Vulnerability analysis

Correct Answer: B

Explanation

The administrator is analyzing repeated login behaviors and time-based patterns that precede successful access. Pattern recognition allows the AI model to detect these behavioral trends, improving its ability to identify anomalies or potential attacks while aligning with normal office-hour login behavior.

Question 9 (source: page 3)

Which of the following is the most concerning risk for a company that allows corporate end users to use public-facing large language models (LLMs)?

- A. Inaccuracies due to hallucinations
- B. Out-of-date acceptable use policies
- C. Data security regulatory violations [Correct]**
- D. Malicious code generation

Correct Answer: C

Explanation

The greatest concern with employees using public-facing LLMs is the potential exposure of sensitive or regulated corporate data. Submitting such information to external systems may violate data protection laws (e.g., GDPR, HIPAA), creating legal and compliance risks that outweigh issues like hallucinations or malicious outputs.

Question 10 (source: page 3)

Which of the following requires developers to harden infrastructure to protect AI systems?

- A. Intake processes
- B. Acceptable use policies
- C. Development guidelines
- D. Configuration standards [Correct]**

Correct Answer: D

Explanation

Configuration standards define how infrastructure and systems must be securely set up and maintained. By following these standards, developers harden the environment that supports AI systems, reducing risks from

misconfigurations and vulnerabilities.

Question 11 (source: page 3)

Which of the following is the best example of an AI model that is trained to identify multiple points from input using a neural network to provide output for authentication?

- A. Facial recognition [Correct]**
- B. Encryption key
- C. Open Authorization (OAuth)
- D. Bounding box

Correct Answer: A

Explanation

Facial recognition uses neural networks to analyze multiple points or features from an input image (such as eyes, nose, mouth, and facial structure) to generate a unique identifier for authentication purposes.

Question 12 (source: page 3)

An organization is developing and implementing AI features into a customer service application. Which of the following practices should the organization put the place before releasing the application for customer trials?

- A. Data masking and sanitization [Correct]**
- B. External compliance audits
- C. Approved AI vendor lists
- D. Third-party risk management

Correct Answer: A

Explanation

Before releasing AI features for customer trials, it is critical to protect sensitive information that may be used during testing. Data masking and sanitization ensure customer or corporate data is anonymized or obfuscated, reducing the risk of data exposure while still allowing realistic evaluation of the AI system.

Question 13 (source: page 3)

An internal user enters a client credit card number into an internal generative machine learning (ML) model:

#User prompt: Customer Jane Doe has a new credit card that she wants to add to her account. The number is 5555-5555-5555-5555

Which of the following is the most effective way to prevent prompt injection attacks against a large language model (LLM)?

- A. Guardrails [Correct]**
- B. Antivirus
- C. Web application firewall (WAF)
- D. Role-based access control

Correct Answer: A

Explanation

Guardrails are the primary security control for LLMs to prevent prompt injection attacks. They enforce rules on what inputs are accepted and how the model responds, blocking malicious or sensitive prompts (such as credit card numbers) before they can manipulate or exploit the model.

Question 14 (source: page 3)

A security alert triggers an agentic system. An analyst notices the following payload in the logs" The alert includes multiple shell commands that are not typically run as part of any hardening. Which of the following is the most effective control to implement?

- A. Adding logic that includes approved strings before running the shell commands [Correct]**
- B. Deprecating model usage and retaining the model with safer parameters
- C. Modifying the application to ignore the SECURITY_UPDATE tag
- D. Using only approved libraries when interacting with agentic systems

Correct Answer: A

Explanation

The payload in the alert attempts to trick the system into executing unauthorized shell commands. The most effective control is to implement allow-list validation (approved strings) before execution. This ensures that only predefined, safe commands are executed, blocking prompt injection attempts that introduce malicious code such as the fake patch script.

Question 15 (source: page 3)

A global security operations center (SOC) wants to adapt and leverage the strength of AI in order to enhance its security operations. Which of the following is the best way to enhance the global SOC functions?

- A. Generate code and execute in production to help save time.
- B. Enable a personal assistant that can act in the global SOC with no human intervention.
- C. Use open-source models in production to help the efficiency of threat detection and threat analysis.
- D. Summarize alerts to easily gain insights on the environment. [Correct]**

Correct Answer: D

Explanation

AI can significantly enhance SOC operations by summarizing and correlating high volumes of alerts, enabling analysts to quickly identify patterns, prioritize threats, and gain actionable insights. This reduces analyst fatigue and improves response times without introducing unsafe automation risks.

Question 16 (source: page 3)

An attacker successfully completes a denial-of-service (DoS) attack through the context window of an AI system. Thousands of characters are obfuscated and hidden behind an emoji. Which of the following techniques best mitigates this type of attack?

- A. Fraud detection
- B. Large language model (LLM)-as-a-judge
- C. Pattern recognition
- D. Prompt filter [Correct]**

Correct Answer: D

Explanation

A DoS attack through the context window relies on overwhelming the model with excessive or obfuscated input. Prompt filtering prevents such malicious or oversized inputs from being processed, ensuring that the model only receives safe, properly structured data within acceptable limits.

Question 17 (source: page 4)

Which of the following is the most concerning risk for a company that allows corporate end users to use public-facing large language models (LLMs)?

- A. Inaccuracies due to hallucinations
- B. Out-of-date acceptable use policies
- C. Data security regulatory violations [Correct]**
- D. Malicious code generation

Correct Answer: C

Explanation

The greatest concern with employees using public-facing LLMs is the potential exposure of sensitive or regulated corporate data. Submitting such information to external systems may violate data protection laws

(e.g., GDPR, HIPAA), creating legal and compliance risks that outweigh issues like hallucinations or malicious outputs.

Question 18 (source: page 4)

Which of the following requires developers to harden infrastructure to protect AI systems?

- A. Intake processes
- B. Acceptable use policies
- C. Development guidelines
- D. Configuration standards [Correct]**

Correct Answer: D

Explanation

Configuration standards define how infrastructure and systems must be securely set up and maintained. By following these standards, developers harden the environment that supports AI systems, reducing risks from misconfigurations and vulnerabilities.

Question 19 (source: page 4)

Which of the following is the best example of an AI model that is trained to identify multiple points from input using a neural network to provide output for authentication?

- A. Facial recognition [Correct]**
- B. Encryption key
- C. Open Authorization (OAuth)
- D. Bounding box

Correct Answer: A

Explanation

Facial recognition uses neural networks to analyze multiple points or features from an input image (such as eyes, nose, mouth, and facial structure) to generate a unique identifier for authentication purposes.

Question 20 (source: page 4)

An organization is developing and implementing AI features into a customer service application. Which of the following practices should the organization put the place before releasing the application for customer trials?

- A. Data masking and sanitization [Correct]**
- B. External compliance audits
- C. Approved AI vendor lists
- D. Third-party risk management

Correct Answer: A

Explanation

Before releasing AI features for customer trials, it is critical to protect sensitive information that may be used during testing. Data masking and sanitization ensure customer or corporate data is anonymized or obfuscated, reducing the risk of data exposure while still allowing realistic evaluation of the AI system.

Question 21 (source: page 4)

An internal user enters a client credit card number into an internal generative machine learning (ML) model:

#User prompt: Customer Jane Doe has a new credit card that she wants to add to her account.

The number is 5555-5555-5555-5555

Which of the following is the most effective way to prevent prompt injection attacks against a large language model (LLM)?

- A. Guardrails [Correct]**
- B. Antivirus
- C. Web application firewall (WAF)
- D. Role-based access control

Correct Answer: A

Explanation

Guardrails are the primary security control for LLMs to prevent prompt injection attacks. They enforce rules on what inputs are accepted and how the model responds, blocking malicious or sensitive prompts (such as credit card numbers) before they can manipulate or exploit the model.

Question 22 (source: page 4)

A security alert triggers an agentic system. An analyst notices the following payload in the logs" The alert includes multiple shell commands that are not typically run as part of any hardening. Which of the following is the most effective control to implement?

- A. Adding logic that includes approved strings before running the shell commands [Correct]**
- B. Deprecating model usage and retaining the model with safer parameters
- C. Modifying the application to ignore the SECURITY_UPDATE tag
- D. Using only approved libraries when interacting with agentic systems

Correct Answer: A

Explanation

The payload in the alert attempts to trick the system into executing unauthorized shell commands. The most effective control is to implement allow-list validation (approved strings) before execution. This ensures that only predefined, safe commands are executed, blocking prompt injection attempts that introduce malicious code such as the fake patch script.

Question 23 (source: page 4)

A global security operations center (SOC) wants to adapt and leverage the strength of AI in order to enhance its security operations. Which of the following is the best way to enhance the global SOC functions?

- A. Generate code and execute in production to help save time.
- B. Enable a personal assistant that can act in the global SOC with no human intervention.
- C. Use open-source models in production to help the efficiency of threat detection and threat analysis.
- D. Summarize alerts to easily gain insights on the environment. [Correct]**

Correct Answer: D

Explanation

AI can significantly enhance SOC operations by summarizing and correlating high volumes of alerts, enabling analysts to quickly identify patterns, prioritize threats, and gain actionable insights. This reduces analyst fatigue and improves response times without introducing unsafe automation risks.

Question 24 (source: page 4)

An attacker successfully completes a denial-of-service (DoS) attack through the context window of an AI system. Thousands of characters are obfuscated and hidden behind an emoji. Which of the following techniques best mitigates this type of attack?

- A. Fraud detection
- B. Large language model (LLM)-as-a-judge
- C. Pattern recognition
- D. Prompt filter [Correct]**

Correct Answer: D

Explanation

A DoS attack through the context window relies on overwhelming the model with excessive or obfuscated input. Prompt filtering prevents such malicious or oversized inputs from being processed, ensuring that the model only receives safe, properly structured data within acceptable limits.

Question 25 (source: page 5)

Which of the following is the most concerning risk for a company that allows corporate end users to use public-facing large language models (LLMs)?

- A. Inaccuracies due to hallucinations
- B. Out-of-date acceptable use policies
- C. Data security regulatory violations [Correct]**
- D. Malicious code generation

Correct Answer: C

Explanation

The greatest concern with employees using public-facing LLMs is the potential exposure of sensitive or regulated corporate data. Submitting such information to external systems may violate data protection laws

(e.g., GDPR, HIPAA), creating legal and compliance risks that outweigh issues like hallucinations or malicious outputs.

Question 26 (source: page 5)

Which of the following requires developers to harden infrastructure to protect AI systems?

- A. Intake processes
- B. Acceptable use policies
- C. Development guidelines
- D. Configuration standards [Correct]**

Correct Answer: D

Explanation

Configuration standards define how infrastructure and systems must be securely set up and maintained. By following these standards, developers harden the environment that supports AI systems, reducing risks from misconfigurations and vulnerabilities.

Question 27 (source: page 5)

Which of the following is the best example of an AI model that is trained to identify multiple points from input using a neural network to provide output for authentication?

- A. Facial recognition [Correct]**
- B. Encryption key
- C. Open Authorization (OAuth)
- D. Bounding box

Correct Answer: A

Explanation

Facial recognition uses neural networks to analyze multiple points or features from an input image (such as eyes, nose, mouth, and facial structure) to generate a unique identifier for authentication purposes.

Question 28 (source: page 5)

An organization is developing and implementing AI features into a customer service application. Which of the following practices should the organization put the place before releasing the application for customer trials?

- A. Data masking and sanitization [Correct]**
- B. External compliance audits
- C. Approved AI vendor lists
- D. Third-party risk management

Correct Answer: A

Explanation

Before releasing AI features for customer trials, it is critical to protect sensitive information that may be used during testing. Data masking and sanitization ensure customer or corporate data is anonymized or obfuscated, reducing the risk of data exposure while still allowing realistic evaluation of the AI system.

Question 29 (source: page 5)

An internal user enters a client credit card number into an internal generative machine learning (ML) model:

#User prompt: Customer Jane Doe has a new credit card that she wants to add to her account.

The number is 5555-5555-5555-5555

Which of the following is the most effective way to prevent prompt injection attacks against a large language model (LLM)?

- A. Guardrails [Correct]**
- B. Antivirus
- C. Web application firewall (WAF)
- D. Role-based access control

Correct Answer: A

Explanation

Guardrails are the primary security control for LLMs to prevent prompt injection attacks. They enforce rules on what inputs are accepted and how the model responds, blocking malicious or sensitive prompts (such as credit card numbers) before they can manipulate or exploit the model.

Question 30 (source: page 5)

A security alert triggers an agentic system. An analyst notices the following payload in the logs" The alert includes multiple shell commands that are not typically run as part of any hardening. Which of the following is the most effective control to implement?

- A. Adding logic that includes approved strings before running the shell commands [Correct]**
- B. Deprecating model usage and retaining the model with safer parameters
- C. Modifying the application to ignore the SECURITY_UPDATE tag
- D. Using only approved libraries when interacting with agentic systems

Correct Answer: A

Explanation

The payload in the alert attempts to trick the system into executing unauthorized shell commands. The most effective control is to implement allow-list validation (approved strings) before execution. This ensures that only predefined, safe commands are executed, blocking prompt injection attempts that introduce malicious code such as the fake patch script.

Question 31 (source: page 5)

A global security operations center (SOC) wants to adapt and leverage the strength of AI in order to enhance its security operations. Which of the following is the best way to enhance the global SOC functions?

- A. Generate code and execute in production to help save time.
- B. Enable a personal assistant that can act in the global SOC with no human intervention.
- C. Use open-source models in production to help the efficiency of threat detection and threat analysis.
- D. Summarize alerts to easily gain insights on the environment. [Correct]**

Correct Answer: D

Explanation

AI can significantly enhance SOC operations by summarizing and correlating high volumes of alerts, enabling analysts to quickly identify patterns, prioritize threats, and gain actionable insights. This reduces analyst fatigue and improves response times without introducing unsafe automation risks.

Question 32 (source: page 5)

An attacker successfully completes a denial-of-service (DoS) attack through the context window of an AI system. Thousands of characters are obfuscated and hidden behind an emoji. Which of the following techniques best mitigates this type of attack?

- A. Fraud detection
- B. Large language model (LLM)-as-a-judge
- C. Pattern recognition
- D. Prompt filter [Correct]**

Correct Answer: D

Explanation

A DoS attack through the context window relies on overwhelming the model with excessive or obfuscated input. Prompt filtering prevents such malicious or oversized inputs from being processed, ensuring that the model only receives safe, properly structured data within acceptable limits.

Question 33 (source: page 6)

Which of the following is the most concerning risk for a company that allows corporate end users to use public-facing large language models (LLMs)?

- A. Inaccuracies due to hallucinations
- B. Out-of-date acceptable use policies
- C. Data security regulatory violations [Correct]**
- D. Malicious code generation

Correct Answer: C

Explanation

The greatest concern with employees using public-facing LLMs is the potential exposure of sensitive or regulated corporate data. Submitting such information to external systems may violate data protection laws

(e.g., GDPR, HIPAA), creating legal and compliance risks that outweigh issues like hallucinations or malicious outputs.

Question 34 (source: page 6)

Which of the following requires developers to harden infrastructure to protect AI systems?

- A. Intake processes
- B. Acceptable use policies
- C. Development guidelines
- D. Configuration standards [Correct]**

Correct Answer: D

Explanation

Configuration standards define how infrastructure and systems must be securely set up and maintained. By following these standards, developers harden the environment that supports AI systems, reducing risks from misconfigurations and vulnerabilities.

Question 35 (source: page 6)

Which of the following is the best example of an AI model that is trained to identify multiple points from input using a neural network to provide output for authentication?

- A. Facial recognition [Correct]**
- B. Encryption key
- C. Open Authorization (OAuth)
- D. Bounding box

Correct Answer: A

Explanation

Facial recognition uses neural networks to analyze multiple points or features from an input image (such as eyes, nose, mouth, and facial structure) to generate a unique identifier for authentication purposes.

Question 36 (source: page 6)

An organization is developing and implementing AI features into a customer service application. Which of the following practices should the organization put in place before releasing the application for customer trials?

- A. Data masking and sanitization [Correct]**
- B. External compliance audits
- C. Approved AI vendor lists
- D. Third-party risk management

Correct Answer: A

Explanation

Before releasing AI features for customer trials, it is critical to protect sensitive information that may be used during testing. Data masking and sanitization ensure customer or corporate data is anonymized or obfuscated, reducing the risk of data exposure while still allowing realistic evaluation of the AI system.

Question 37 (source: page 6)

An internal user enters a client credit card number into an internal generative machine learning (ML) model:

#User prompt: Customer Jane Doe has a new credit card that she wants to add to her account.

The number is 5555-5555-5555-5555

Which of the following is the most effective way to prevent prompt injection attacks against a large language model (LLM)?

- A. Guardrails [Correct]**
- B. Antivirus
- C. Web application firewall (WAF)
- D. Role-based access control

Correct Answer: A

Explanation

Guardrails are the primary security control for LLMs to prevent prompt injection attacks. They enforce rules on what inputs are accepted and how the model responds, blocking malicious or sensitive prompts (such as credit card numbers) before they can manipulate or exploit the model.

Question 38 (source: page 6)

A security alert triggers an agentic system. An analyst notices the following payload in the logs" The alert includes multiple shell commands that are not typically run as part of any hardening. Which of the following is the most effective control to implement?

- A. Adding logic that includes approved strings before running the shell commands [Correct]**
- B. Deprecating model usage and retaining the model with safer parameters
- C. Modifying the application to ignore the SECURITY_UPDATE tag
- D. Using only approved libraries when interacting with agentic systems

Correct Answer: A

Explanation

The payload in the alert attempts to trick the system into executing unauthorized shell commands. The most effective control is to implement allow-list validation (approved strings) before execution. This ensures that only predefined, safe commands are executed, blocking prompt injection attempts that introduce malicious code such as the fake patch script.

Question 39 (source: page 6)

A global security operations center (SOC) wants to adapt and leverage the strength of AI in order to enhance its security operations. Which of the following is the best way to enhance the global SOC functions?

- A. Generate code and execute in production to help save time.
- B. Enable a personal assistant that can act in the global SOC with no human intervention.
- C. Use open-source models in production to help the efficiency of threat detection and threat analysis.
- D. Summarize alerts to easily gain insights on the environment. [Correct]**

Correct Answer: D

Explanation

AI can significantly enhance SOC operations by summarizing and correlating high volumes of alerts, enabling analysts to quickly identify patterns, prioritize threats, and gain actionable insights. This reduces analyst fatigue and improves response times without introducing unsafe automation risks.

Question 40 (source: page 6)

An attacker successfully completes a denial-of-service (DoS) attack through the context window of an AI system. Thousands of characters are obfuscated and hidden behind an emoji. Which of the following techniques best mitigates this type of attack?

- A. Fraud detection
- B. Large language model (LLM)-as-a-judge
- C. Pattern recognition
- D. Prompt filter [Correct]**

Correct Answer: D

Explanation

A DoS attack through the context window relies on overwhelming the model with excessive or obfuscated input. Prompt filtering prevents such malicious or oversized inputs from being processed, ensuring that the model only receives safe, properly structured data within acceptable limits.

Question 41 (source: page 7)

Which of the following is the most concerning risk for a company that allows corporate end users to use public-facing large language models (LLMs)?

- A. Inaccuracies due to hallucinations
- B. Out-of-date acceptable use policies
- C. Data security regulatory violations [Correct]**
- D. Malicious code generation

Correct Answer: C

Explanation

The greatest concern with employees using public-facing LLMs is the potential exposure of sensitive or regulated corporate data. Submitting such information to external systems may violate data protection laws

(e.g., GDPR, HIPAA), creating legal and compliance risks that outweigh issues like hallucinations or malicious outputs.

Question 42 (source: page 7)

Which of the following requires developers to harden infrastructure to protect AI systems?

- A. Intake processes
- B. Acceptable use policies
- C. Development guidelines
- D. Configuration standards [Correct]**

Correct Answer: D

Explanation

Configuration standards define how infrastructure and systems must be securely set up and maintained. By following these standards, developers harden the environment that supports AI systems, reducing risks from misconfigurations and vulnerabilities.

Question 43 (source: page 7)

Which of the following is the best example of an AI model that is trained to identify multiple points from input using a neural network to provide output for authentication?

- A. Facial recognition [Correct]**
- B. Encryption key
- C. Open Authorization (OAuth)
- D. Bounding box

Correct Answer: A

Explanation

Facial recognition uses neural networks to analyze multiple points or features from an input image (such as eyes, nose, mouth, and facial structure) to generate a unique identifier for authentication purposes.

Question 44 (source: page 7)

An organization is developing and implementing AI features into a customer service application. Which of the following practices should the organization put in place before releasing the application for customer trials?

- A. Data masking and sanitization [Correct]**
- B. External compliance audits
- C. Approved AI vendor lists
- D. Third-party risk management

Correct Answer: A

Explanation

Before releasing AI features for customer trials, it is critical to protect sensitive information that may be used during testing. Data masking and sanitization ensure customer or corporate data is anonymized or obfuscated, reducing the risk of data exposure while still allowing realistic evaluation of the AI system.

Question 45 (source: page 7)

An internal user enters a client credit card number into an internal generative machine learning (ML) model:

#User prompt: Customer Jane Doe has a new credit card that she wants to add to her account.

The number is 5555-5555-5555-5555

Which of the following is the most effective way to prevent prompt injection attacks against a large language model (LLM)?

- A. Guardrails [Correct]**
- B. Antivirus
- C. Web application firewall (WAF)
- D. Role-based access control

Correct Answer: A

Explanation

Guardrails are the primary security control for LLMs to prevent prompt injection attacks. They enforce rules on what inputs are accepted and how the model responds, blocking malicious or sensitive prompts (such as credit card numbers) before they can manipulate or exploit the model.

Question 46 (source: page 7)

A security alert triggers an agentic system. An analyst notices the following payload in the logs" The alert includes multiple shell commands that are not typically run as part of any hardening. Which of the following is the most effective control to implement?

- A. Adding logic that includes approved strings before running the shell commands [Correct]**
- B. Deprecating model usage and retaining the model with safer parameters
- C. Modifying the application to ignore the SECURITY_UPDATE tag
- D. Using only approved libraries when interacting with agentic systems

Correct Answer: A

Explanation

The payload in the alert attempts to trick the system into executing unauthorized shell commands. The most effective control is to implement allow-list validation (approved strings) before execution. This ensures that only predefined, safe commands are executed, blocking prompt injection attempts that introduce malicious code such as the fake patch script.

Question 47 (source: page 7)

A global security operations center (SOC) wants to adapt and leverage the strength of AI in order to enhance its security operations. Which of the following is the best way to enhance the global SOC functions?

- A. Generate code and execute in production to help save time.
- B. Enable a personal assistant that can act in the global SOC with no human intervention.
- C. Use open-source models in production to help the efficiency of threat detection and threat analysis.
- D. Summarize alerts to easily gain insights on the environment. [Correct]**

Correct Answer: D

Explanation

AI can significantly enhance SOC operations by summarizing and correlating high volumes of alerts, enabling analysts to quickly identify patterns, prioritize threats, and gain actionable insights. This reduces analyst fatigue and improves response times without introducing unsafe automation risks.

Question 48 (source: page 7)

An attacker successfully completes a denial-of-service (DoS) attack through the context window of an AI system. Thousands of characters are obfuscated and hidden behind an emoji. Which of the following techniques best mitigates this type of attack?

- A. Fraud detection
- B. Large language model (LLM)-as-a-judge
- C. Pattern recognition
- D. Prompt filter [Correct]**

Correct Answer: D

Explanation

A DoS attack through the context window relies on overwhelming the model with excessive or obfuscated input. Prompt filtering prevents such malicious or oversized inputs from being processed, ensuring that the model only receives safe, properly structured data within acceptable limits.
